Politechnika Krakowska
im. Tadeusza Kościuszki

Wydział Informatyki i Matematyki

Wiktor Zmiendak

Numer albumu: 142706

Sprawozdanie

Wykrywanie zagrożeń i reakcji na incydenty

Laboratorium nr 1

Przebieg ataku:

Celem tego laboratorium było przeanalizowanie ataku z użyciem oprogramowania malware do którego doszło 19 marca 2019 na komputer z systemem Windows.

Z przeprowadzonej analizy wynika, że pierwszy alert dotyczył protokołu UDP, którego celem według zamieszczonej w nim wiadomości była aktualizacja polityki DNS („ET POLICY DNS Update from External net”). Tego typu alert może jednak świadczyć o błędzie w konfiguracji IDS na co wskazuje fakt, że zarazem źródłem jak i celem była ta sama sieć wewnętrzna. Drugi zanotowany alert pokazuje jednak request typu GET z plikiem test1.exe. Odczytując sygnaturę pliku (MZ) można wywnioskować, że jest to plik wykonywalny mogący stanowić niebezpieczeństwo w postaci malwaru.

W celu przeprowadzenia analizy podejrzanego pliku tworzymy na jego podstawie hash SHA256, który po sprawdzeniu na stronie talosintelligence.com okazuje się być w rzeczywistości malwarem typu trojan.

Analizując kolejne alerty odkrywamy, że system IDS rozpoznał ten rodzaj oprogramowania malware jako Remcos RAT. Służy on do zdalnego przejmowania kontroli nad hostem. Do nawiązania połączenia posłużono się w tym przypadku portem 2404, który nie jest znany ani też używany, a sama komunikacja była zaszyfrowana. Malware prawdopodobnie zbierał informację wychodzące od serwera i wyczekiwał momentu, kiedy może przystąpić do ataku. Sprawdzając kolejne alerty możemy zaleźć jeszcze 3 pobrane pliki, gdzie nie każdy z nich wygląda na szkodliwe oprogramowanie. Jest to popularny zabieg wykorzystywany do ukrycia swojego ruchu sieciowego pośród

pozornie nieszkodliwych zapytań. W tym przypadku są one związane z usługą firmy Microsoft sprawdzającą status połączenia z siecią.

Kolejnym krokiem w naszej analizie było sprawdzenie przy pomocy narzędzia Kibana alertów odpowiadających przedziałowi czasowemu kiedy doszło do ataku. Znajdujemy tam event który pokazuje nam te same alerty analizowane wcześniej. Po oczytaniu szczegółów możemy znaleźć informację, że pochodzą one z Newcastle natomiast samo źródło zapytań wskazuje na Bombaj w Indiach.